

1. Phân tích Chi tiết Lỗ hổng bảo mật (Vulnerabilities) - Điểm E

Dựa trên hình ảnh thực tế từ file cấu hình Backend (application.properties), hệ thống đang dính lỗi cực kỳ nghiêm trọng:

- **Tên lỗi phát hiện: Hardcoded Secrets / Credential Exposure** (Lộ thông tin xác thực nhạy cảm trực tiếp trong mã nguồn).
- **Vị trí file lỗi:** backend-horse-racing-management/src/main/resources/application.properties (dòng 1).
- **Chi tiết thực tế trên code:**
 - o Đoạn cấu hình kết nối MongoDB đang để lộ nguyên chuỗi kết nối (Connection String) bao gồm cả username và password dạng plain-text:
spring.data.mongodb.uri=mongodb+srv://1945musictrending_db_user:[PASSWORD]@mongostudy....
- **Mức độ nguy hiểm: CRITICAL / BLOCKER (Điểm E).** Nếu đẩy code này lên một Public Repository trên GitHub, bất kỳ ai cũng có thể lấy được quyền truy cập vào cơ sở dữ liệu chính của hệ thống.
- **Hướng giải quyết (Action Plan cho Dev):**
 1. Xóa ngay lập tức chuỗi thông tin tài khoản/mật khẩu đang viết cứng trong file application.properties.
 2. Chuyển sang sử dụng biến môi trường (Environment Variables) hoặc cấu hình qua Spring Cloud Config / Docker Secrets.

2. Phân tích Các vấn đề bảo mật ở Frontend (Mã nguồn giao diện)

Dựa trên các hình ảnh về file RaceSimulation.jsx, SonarQube cũng ghi nhận các cảnh báo về chất lượng và bảo mật (Rating C):

- **Vị trí file:** frontend-horse-racing-management/src/pages/client/RaceSimulation/RaceSimulation.jsx.
- **Vấn đề phát hiện:**
 - Sử dụng hàm tạo số ngẫu nhiên không an toàn cho thuật toán mô phỏng: Math.random(). SonarQube cảnh báo việc dùng Math.random() trong các logic nhạy cảm có thể dễ dàng bị dự đoán trước kết quả (rất nguy hiểm đối với các module liên quan đến cá cược, xác suất trúng thưởng).
- **Hướng giải quyết (Action Plan cho Dev):**
 - Thay thế Math.random() bằng các hàm sinh số ngẫu nhiên có độ bảo mật cao hơn (Cryptographically secure pseudorandom number

generator - CSPRNG) nếu đoạn code đó ảnh hưởng trực tiếp đến kết quả tính toán cược của người chơi.

3. Đánh giá tổng kết cho Báo cáo Nhóm

- **Security Hotspots:** Ghi nhận **0** điểm nóng cần review thủ công.
- **Tổng số Vulnerabilities:** Hệ thống đang có các lỗi cần xử lý gấp để nâng điểm Security từ **E** lên **A**.
- **Trọng tâm công việc cho Sprint này:** Giao ngay task cho Backend fix lộ thông tin ở `application.properties` và giao cho Frontend xử lý việc dùng hàm `random` bảo mật hơn ở `RaceSimulation.jsx`.